

CYBER WINTER

- WEEK 1 - INTRODUCTION TO CYBERSECURITY ANDETHICAL HACKINGWITHSYLLABUSDISTRIBUTION
- WEEK 2 - NETWORKING FUNDAMENTALS FORETHICALHACKING
- WEEK 3 - INTRODUCTION TO FOOTPRINTING AND RECONNAISSANCE
- WEEK 4 - SCANNING AND ENUMERATION TECHNIQUES
- WEEK 5 - SYSTEM AND NETWORK EXPLOITATION BASICS WITH WIRELESS ATTACKS
- WEEK 6 - WEB APPLICATION SECURITY FUNDAMENTALS , REMEDIATIONS AND REPORTING

SCANNING AND ENUMERATION TECHNIQUES



This week,we're divingintothe essential tools and techniques for scanning and discovering information about networks and devices.

What is Scanning?

It is like a security guard inspecting a building. Instead of checking rooms and doors, we scan computers and networks to understand what's open, what's locked, and where there might be vulnerabilities.

Purpose of Scanning

The goal of scanning is to gather information about a network or a system. By scanning, we can detect which devices are connected, which services are running, and if there are any weaknesses that could be exploited by a hacker.

Scanning helps cybersecurity professionals detect vulnerabilities early so they can fix them before they are exploited by hackers. It's a proactive approach to ensure security.

TYPES OF SCANS

Therearedifferenttypesofscansincybersecurity, each serving a uniquepurpose.Hereareafewtypeswe'llexplore in depth later.



Network Scanning

Itisa procedure of identifying active hosts on a network, either to attack or access the security of the network. **Example**: Similar to counting the number of people in a building and what each room is used for.

Port Scanning

Itisthe process of checking the services running on the target computer by sending a sequence of messages in a attempt to break in. **Example**: Just like testing of each door in a building to see if it's locked (Port listening state) or not.

Vulnerability Scanning

It is amethod for checking whether a system is exploitable by identifying its Vulnerabilities. **Example**: Weak windows and door locks in a building.

TECHNIQUES OF SCANNING

Key Techniques Used in Scanning





- **Active Scanning**: Sending requests directly to devices to gather information about their status. It's like asking every person in a building, "Who are you and what's your role here?"
- **Passive Scanning**: Observing network traffic without directly interacting with devices. It's like Watching people in a building to figure out their routines without asking questions.

Common Scanning Methods

01 **SYN Scan (Half-Open Scan):** Quickly identifies open ports without fully establishing a connection. It's like knocking on a door to see if someone answers, without actually entering.

02 **Ping Sweep:** Checks which devices are active and reachable on a network. It's like sending a message to everyone in a building asking, "Are you here?" and waiting for responses.

03 **Port Scanning:** Determines which ports are open and what services are running. It's like testing every door in a building to see if it's locked or unlocked.

OBJECTIVE OF SCANNING



1.HostDiscovery

It is a first step in network scanning, aimed at identifying live devices within a given IP range. By determining which hosts are active, penetration testers or attackers can focus their efforts on specific targets instead of wasting time on inactive systems.

Methods:

01 **Ping sweeps:** Using ICMP packets to check for responses.

02 **ARP requests:** Resolving IP addresses to MAC addresses in local networks.

03 **TCP SYN/ACK scanning:** Sending packets to specific ports and analyzing responses to determine activity.

04 **DNS lookups:** Resolving hostnames to identify active systems.

OBJECTIVE OF SCANNING



2. OS and Service Detection

This step involves gathering information about the type of operating system (OS) and the services (applications or protocols) running on open ports. The insights help in identifying vulnerabilities specific to those OS versions or services.

Methods:

01 **Banner grabbing:** Analyzing response headers from services like HTTP or SMTP to deduce software and version details.

02 **Fingerprinting techniques:** Using tools like Nmap to infer the OS and services based on subtle differences in response behavior, packet structure, or time-to-live (TTL) values.

03 **Service enumeration:** Querying open ports to list specific applications and their versions.

OBJECTIVE OF SCANNING



3. UDP Scanning

Unlike TCP, UDP (User Datagram Protocol) is connectionless, making it more challenging to scan. UDP scanning focuses on discovering services like DNS, SNMP, or TFTP that use UDP instead of TCP.

Challanges:

01 No direct acknowledgment packets as in TCP.

02 High rate of packet loss or filtering by firewalls.

Methods:

01 **Send probes:** Send empty or protocol-specific packets to common UDP ports.

02 **Analyze responses:** Evaluate responses like ICMP port unreachable messages or service-specific replies to deduce if the port is open or filtered.

OBJECTIVE OF SCANNING



4. Stealth Scans

Stealth scans are designed to evade detection by avoiding direct or complete connection to the target. The goal is to bypass logging mechanisms or trigger fewer alarms while still gathering necessary information.

Methods:

01 **Half-open (SYN) scan:** Initiate a TCP handshake but never complete it. Tools like Nmap use this to determine port states discreetly.

02 **Idle scan:** Exploit a third-party "zombie" system to relay scanning packets, masking the attacker's identity.

03 **Fragmented packets:** Split scanning packets into smaller fragments to evade detection systems.

OBJECTIVE OF SCANNING



5. Firewall Evasion

Firewalls often block unauthorized traffic based on predefined rules. Firewall evasion techniques are used to bypass these barriers to perform effective scanning and reconnaissance.

Methods:

01 **Using decoy IPs:** Spoofing multiple IP addresses to confuse logging systems about the attacker's origin.

02 **Fragmentation:** Sending fragmented packets to bypass deep packet inspection (DPI).

03 **Timing techniques:** Scanning at very slow rates to avoid triggering rate-based alarms.

04 **Protocol manipulation:** Using less commonly monitored protocols or tunneling traffic through HTTP/HTTPS.

IMPORTANCE IN REAL-WORLD APPLICATION

Companies often perform scans on their own networks to find vulnerabilities before hackers do. Just like a company might review building security regularly, a cybersecurity team scans systems to stay one step ahead of potential threats.



NETWORK SCANNING



Overview of Network Scanning

01 Network Scanning refers to a set of procedures used for Identifying hosts, ports, and Services in a network.

02 It is one of the components of intelligence gathering which can be used by an attacker to create a profile of the target organization.

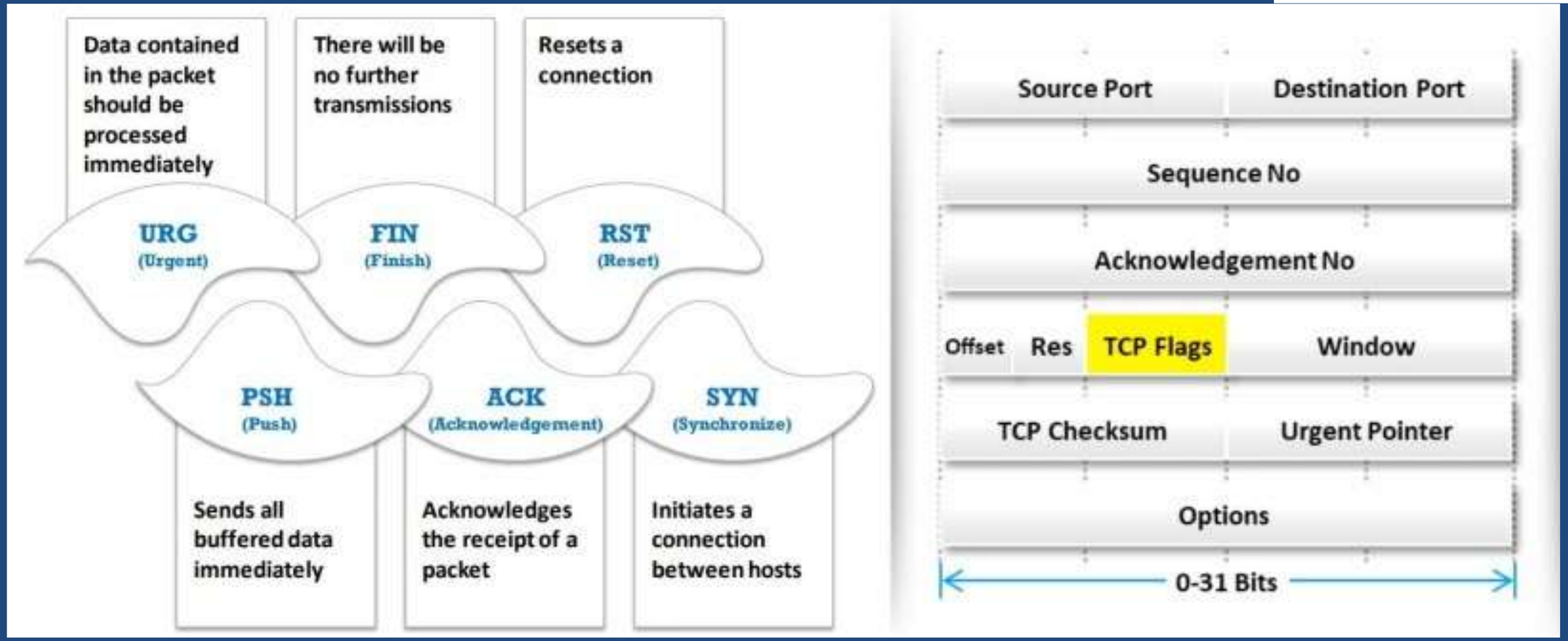
Objectives of Network Scanning

01 To Discover live hosts, IP addresses, and Open ports and services of live hosts with Vulnerabilities.

02 To Discover Operating Systems and System architecture.

Imagine entering a large office building and wanting to list all the rooms and who is inside each one. Network scanning is like walking down each hallway, checking every room, and noting down who or what is there.

NETWORK SCANNING



TCP Communication Flags

The TCP header contains various flags that control the transmission of data across a TCP connection. 6 TCP control flags manage the connection between hosts and give instructions to the system.

SYN, ACK, FIN, and RST govern the establishment, maintenance, and termination of a connection.
PSH and URG provide instructions to the System.

TCP COMMUNICATION FLAG

01 **Synchronize or "SYN":** It notifies transmission of a new sequence number. First flag in 3-way-Handshake.

02 **Acknowledgement or "ACK":** It confirms the receipt of the transmission and identifies the next expected SYN.

When the system successfully receives a packet, value of ACK is set to "1".

03 **Reset or "RST":** When there is an error in the current connection, this flag is set to "1" and the connection is aborted. Attackers use this flag to scan hosts and identify open ports.

04 **Finish or "FIN":** It is set to "1" when no more transmissions will be sent to the remote system (SYN flag is terminated).

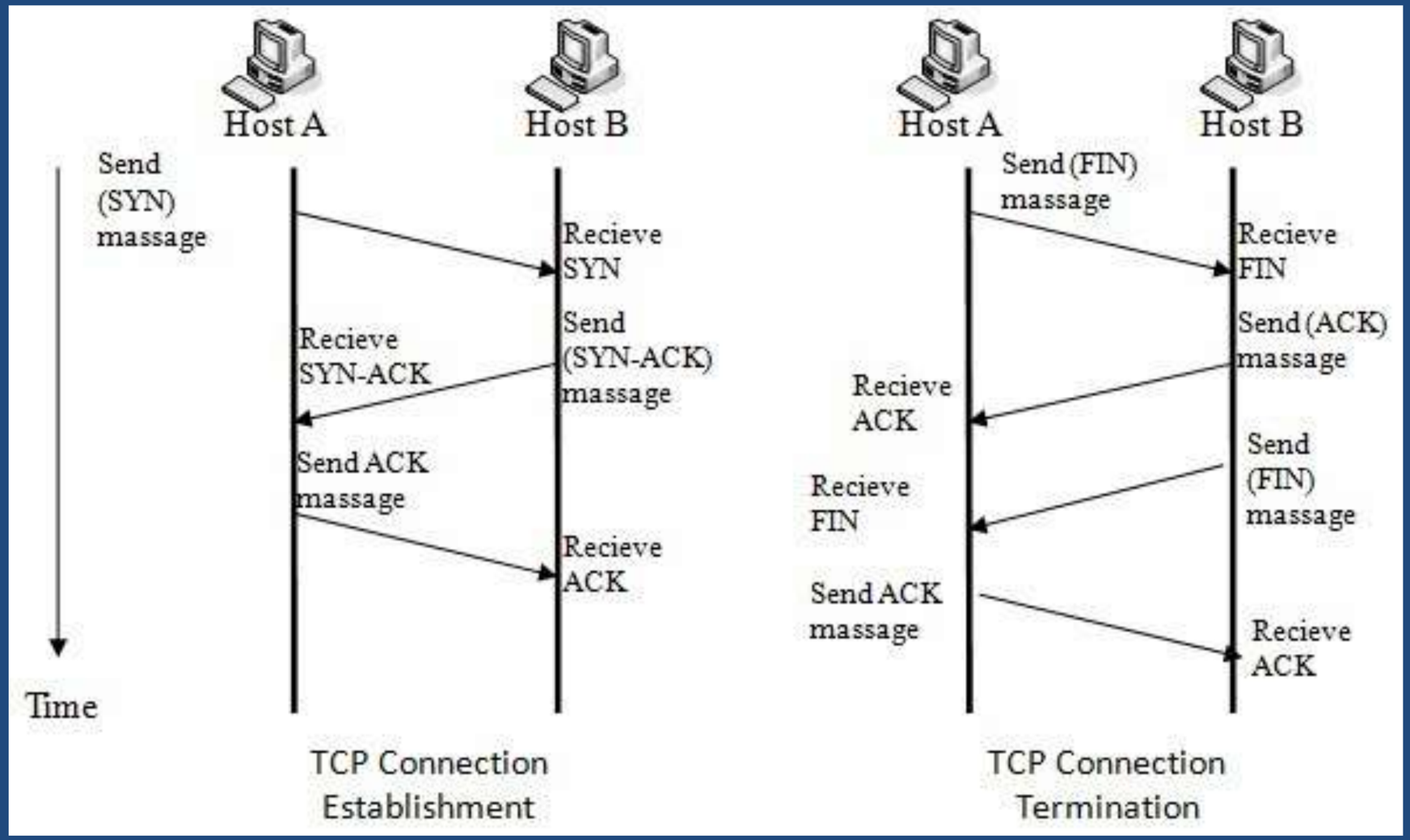
05 **Push or "PSH":** It is set to "1" when the remote system informs the receiving application about the buffered data which is coming from the sender's side. System puts PSH flag at the start and end of data transfer (to prevent buffer deadlock).

06 **Urgent or "URG":** It is set to "1" when system instructs to process the data contained in packets as soon as possible. This flag sets for priority that to whom priority has to be given for processing and all other data process should stop.



Note: SYN scanning includes SYN, ACK, and RST flags which can be used for gathering illegal information from servers during enumeration.

TCP/IP COMMUNICATION



TCP is connection oriented, i.e., it prioritizes connection establishment before data transfer between applications. This connection between protocols is possible through the three-way-handshake.

PORT SCANNING



Overview of Port Scanning

01 Port scanning examines the ports on a device to see which ones are open (accepting connections) or closed (rejecting connections).

02 Open Ports provides information about the OS and the application currently in use.

Why It's Important

01 Open ports could expose services that hackers might target (e.g., file-sharing services or outdated applications).

02 Helps determine the services running on a device.

Tools we can use: *Nmap, Masscan, and Zenmap and much more.*

Think of a house with many doors and windows. Each door or window represents a port. Port scanning is like walking around the house and checking if a door is open, locked, or broken. For instance, an unlocked door might lead to the living room (representing a service), which could be accessed by a thief (hacker) if not secured.

VULNERABILITY SCANNING



Overview of Vulnerability Scanning

01 Vulnerability scanning looks for weaknesses in the devices, services, or applications running on a network.

02 It identifies security flaws like outdated software, weak passwords, or misconfigured systems.

Why It's Important

01 Hackers actively search for vulnerabilities to exploit.

02 Finding these vulnerabilities first allows you to fix them before they are used against you.

Tools we can use: *Nessus, OpenVAS, and Qualys and much more.*

Imagine a building inspector checking a house for cracks in walls, loose locks, or faulty wiring. These issues might not seem urgent now, but they could lead to bigger problems (like a break-in or a fire) if ignored. Similarly, vulnerability scanning ensures that weaknesses in a network are fixed before they cause harm.

WEAK VULNERABILITIES TO SCAN AND CHECK

Vulnerabilities are weaknesses or flawsinasystem,application, ornetworkthat attackers can exploitto gain unauthorizedaccessorcause damage.



Common weak Vulnerabilities found during Scanning

01 **Default or Weak Passwords:** Many devices or applications come with default usernames and passwords (e.g., "admin" / "password"). If these aren't changed, attackers can easily guess them. Imagine a hotel using the same key for every room. If someone finds the key, they can unlock every door.

02 **Outdated Software:** Older versions of software may have known vulnerabilities that hackers can exploit. Imagine using an old car without airbags. It still works, but it's not safe against modern threats. **Open Ports:** Unnecessary open ports can expose services that attackers can exploit. For instance, an open port running an insecure file-sharing service could allow unauthorized access. It is like leaving a window open in a secure building.

03

04 **Misconfigured Systems:** A system that isn't set up properly, like a firewall with loose rules, can allow unauthorized access or traffic. Suppose a security guard forgetting to lock a door after hours. Even the best systems fail if they aren't configured properly.

05 **Unpatched Vulnerabilities:** When software companies release updates (patches) to fix security issues, unpatched systems remain exposed. It is like ignoring a recall notice for a faulty car part. The flaw remains a risk until it's fixed.

WEAK VULNERABILITIES TO SCAN AND CHECK





The Importance of Proactive Scanning

Addressing these vulnerabilities early can stop attackers from exploiting them. Regularly inspecting a building for broken locks or faulty alarms ensures that no weaknesses are overlooked, making the building safer.

Basic Tools Used to Detect Vulnerabilities

01 **Nessus:** Detects common vulnerabilities like weak passwords, outdated software, and missing patches.

02 **OpenVAS:** A free vulnerability scanner that identifies misconfigurations and security flaws.

03 **Qualys:** A professional tool for detecting and managing vulnerabilities.

DIFFERENT TYPES OF TOOLS FOR DIFFERENT TYPES OF SCANNING

1. Network Scanning Tools

- **Nmap (Network Mapper):** Anopen-source toolfornetwork discovery,portandvulnerabilityscanning, OS detection and service enumeration.
- **Masscan:** High-speed port scanner capable of scanning the entire Internet.
- **Unicornscan:** Useful for large-scale network reconnaissance.

2.Vulnerability Scanners

- **Nessus:** Comprehensive vulnerability scanner for identifying network vulnerabilities. It is best in detailed scans and compliance checks.
- **OpenVAS (Greenbone Vulnerability Manager):** Open-source vulnerability scanning framework which is highly configurable with scheduled scans. **Qualys:** Cloud-based vulnerability scanner with advanced analytics.
-

3.Web Application Scanning Tools

- **Nikto:** A web server scanner for detecting outdated versions, misconfigurations, and vulnerabilities. **OWASP ZAP (Zed Attack Proxy):** Open-
- source web application security scanner which is used in proxy-based scanning with active and passive scan modes. **Burp Suite (Community & Pro):** A powerful tool for web application security testing and mostly used in Vulnerability scanning, spidering, and manual testing capabilities.
-

4.DNS and Network Enumeration

- **dnsenum:** Enumerates DNS information, including subdomains and zone transfers.
- **Fierce:** A DNS enumeration tool for locating non-contiguous IPs. **Sublist3r:**
- Subdomain enumeration tool using multiple public sources.

DIFFERENT TYPES OF TOOLS FOR DIFFERENT TYPES OF SCANNING

5.Packet Analysis

- **Wireshark:** A network protocol analyzer for capturing, inspecting live traffic, layer-wise packet analysis and filtering.
- **tcpdump:** Command-line packet analyzer.

6.OSINT (Open Source Intelligence) Tools

- **Recon-ng:** A web reconnaissance framework for gathering OSINT data. Modular with automated workflows.
- **Shodan:** Search engine for identifying exposed devices and services on the Internet. **theHarvester:** An OSINT
- tool for gathering emails, subdomains, and hosts.

7.Active Directory Enumeration

- **BloodHound:** Graph-based tool for analyzing AD trust relationships. Useful for privilege escalation paths.
- **Enum4linux:** Used for enumerating SMB shares and Active Directory information.

8.Specialized Tools

- **Metasploit Framework:** Comes with auxiliary modules for scanning and enumeration.
- **FOCA:** A tool for metadata extraction from documents (e.g., PDFs, Word files).

Suggested Approach:

1.**Start with reconnaissance:** Use OSINT tools (e.g., theHarvester, Shodan). 2.**Follow up with network scans:** Use Nmap and Masscan to identify live hosts and open ports. 3.**Dive into vulnerabilities:** Use Nessus or OpenVAS to identify specific vulnerabilities. 4.**Combine with manual testing:** Tools like Wireshark or Burp Suite for deeper insights.

INTRODUCTION TO CRYPTOGRAPHY AND STEGANOGRAPHY

What is Cryptography?

Cryptography is the practice of securing information by transforming it into a formatthat unauthorized users cannot understand.

It is like, sending a coded message that only the recipient can decode using a secret key (e.g.,

turning “HELLO” into “IFMMP” by shifting each letter).





Key Concepts of Cryptography

- **Encryption:** Converting plain text (readable information) into cipher text (unreadable format). Example: Encrypting “password123” into “Gd$!Fz84Jkl” so hackers cannot understand it. **Decryption:** Reversing
- encryption to return cipher text to its original readable form. Example: Using a password to unlock an encrypted file. **Keys:** Secret codes used for encrypting and decrypting
- data. Example: Think of a locker that only opens with a specific key.

TYPES OF CRYPTOGRAPHY

- **Symmetric Encryption:** Uses the same key for encryption and decryption. Imagine locking and unlocking a suitcase with one key.
- **Asymmetric Encryption:** Uses a pair of keys like one for encryption (public key) and another for decryption (private key). It’s same as sharing a mailbox key publicly so anyone can drop messages, but only you have the private key to open the mailbox and read them.



DIFFERENT TYPES OF ENCRYPTION



Symmetric Encryption

01 Encryption that uses the same key for both encryption and decryption. Wi-Fi Security: WPA2 uses AES encryption to secure communication between your device and the router.

Types of Symmetric Encryption

01 **Block Ciphers**: Encrypt data in fixed-size blocks.

- **AES (Advanced Encryption Standard):** Widely used, highly secure. **DES**
- **(Data Encryption Standard):** Outdated and insecure today. **3DES (Triple**
- **DES):** More secure variant of DES, now largely replaced by AES.

02 **Stream Ciphers:** Encrypt data one bit or byte at a time.

- **RC4:** A stream cipher, deprecated due to vulnerabilities.
- **BlowFish:** Used in some VPNs and file encryption tools.

Advantage / Disadvantage

01 **Advantage:** High-speed encryption suitable for large data also Simpler implementation than asymmetric encryption.

02 **Disadvantage:** The key must be shared securely, if intercepted, security is compromised. That's why it is not suitable for applications requiring key management at scale.

DIFFERENT TYPES OF ENCRYPTION



Asymmetric Encryption

01 Uses a pair of keys: a public key for encryption and a private key for decryption. **Secure Websites (HTTPS):** During a secure connection, a website uses asymmetric encryption (via SSL/TLS) to exchange symmetric keys.

Types of Asymmetric Encryption

01 **RSA (Rivest-Shamir-Adleman):** Commonly used for secure key exchange and digital signatures.

02 **ECC (Elliptic Curve Cryptography):** Efficient with smaller key sizes, used in mobile apps and IoT devices.

03 **DSA (Digital Signature Algorithm):** Used for verifying digital signatures in software like SSH.

04 **Diffie-Hellman:** Securely exchanges keys in protocols like TLS.

Advantage / Disadvantage

01 **Advantage:** Eliminates the need to share private keys and enables digital signatures for authenticity and integrity.

02 **Disadvantage:** Computationally intensive and slower and less efficient for encrypting large volumes of data.

DIFFERENT TYPES OF ENCRYPTION



Hashing (One-Way Encryption)

01 Transforms data into a fixed-size hash value that cannot be reversed. **Password Storage:** Websites store hashed passwords to prevent exposure even if the database is leaked.

Types of Hashing

01 **SHA (Secure Hash Algorithm):**
- **SHA-256:** Widely used for data integrity in blockchain and digital certificates.
- **SHA-1:** Deprecated due to security flaws.

02 **MD5 (Message Digest 5):** Fast but insecure, mainly used for checksums.

03 **Bcrypt:** Commonly used for securely hashing passwords.

Advantage / Disadvantage

01 **Advantage:** Ensures data integrity and protects sensitive information like passwords.

02 **Disadvantage:** Vulnerable to brute force or rainbow table attacks if not salted and cannot recover original data from the hash.

DIFFERENT TYPES OF ENCRYPTION



Hybrid Encryption

01 Combines symmetric and asymmetric encryption for enhanced security and speed. **Secure File Transfers:** Tools like WhatsApp and Signal use hybrid encryption for end-to-end encrypted messages.

Types of Hybrid Encryption

01 **TLS/SSL (Transport Layer Security):** Uses RSA for key exchange and AES for data encryption.

02 **PGP (Pretty Good Privacy):** Combines RSA or ECC with symmetric encryption like AES for secure email communication.

Advantage / Disadvantage

01 **Advantage:** Combines the best of both encryption types and efficient for large-scale data transmission.

02 **Disadvantage:** Complex to implement and also relies on the security of both encryption methods.

DIFFERENT TYPES OF ENCRYPTION



Homomorphic Encryption

01 Allows computations on encrypted data without decrypting it. **Cloud Computing:** Performing analytics on encrypted medical records without exposing sensitive data.

Types of Homomorphic Encryption

01 **Paillier Cryptosystem:** Enables additive homomorphic operations.

02 **BFV (Brakerski/Fan-Vercauteren):** Supports both additive and multiplicative operations, used in research and cloud applications.

03 **CKKS (Cheon-Kim-Kim-Song):** Optimized for approximate arithmetic operations.

Advantage / Disadvantage

01 **Advantage:** Maintains data confidentiality and useful for sensitive industries like healthcare and finance.

02 **Disadvantage:** Computationally expensive and limited support in real-world applications.

DIFFERENT TYPES OF ENCRYPTION



Quantum Encryption

01 Utilizes quantum mechanics to secure data against eavesdropping. **High-Security Networks:** Governments and financial institutions experimenting with QKD for secure communication.

Types of Quantum Encryption

01 **BB84 Protocol:** One of the first Quantum Key Distribution (QKD) protocols.

02 **E91 Protocol:** Based on quantum entanglement for secure key exchange

Advantage / Disadvantage

01 **Advantage:** Resistant to attacks from quantum computers and future-proof for highly sensitive data.

02 **Disadvantage:** Expensive and requires specialized hardware and limited deployment.

INTRODUCTION TO CRYPTOGRAPHY AND STEGANOGRAPHY

What is Steganography?

Steganography is the art of hiding messages within other forms of media so that noone suspects a secret message exists.

It is like, Writing a secret message in invisible ink or hiding it in a picture or song.





How Steganography Works?

- **Image Steganography:** Hiding data within images by altering tiny pixels that are imperceptible to the human eye. Suppose, an ordinary family photo could have hidden text saying “Meet at 7 PM.” **Audio**
- **Steganography:** Embedding secret messages in sound files by altering inaudible frequencies. Now, think a song that sounds normal but contains hidden data. **Video**
- **Steganography:** Encoding messages into video frames. Imagine, a YouTube video or The Simpsons cartoons that has secret data embedded within its visuals.

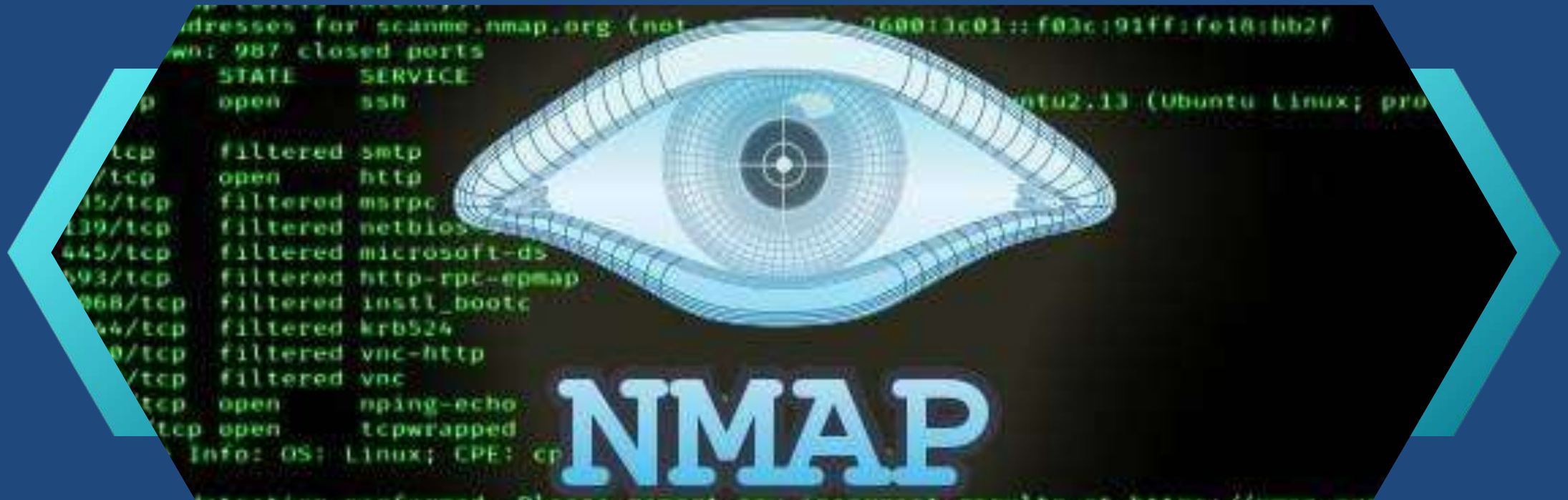
PRACTICAL EXERCISE 1

Nmap Tool: Understanding Results

Purpose and Activity

01 Nmap is Used for scanning networks to identify open ports, services, and potential vulnerabilities.

02 Conduct a basic Nmap scan on a local network and analyze the results: open ports, detected services, and their potential risks.



PRACTICAL EXERCISE 1.1

Commands of Nmap Tool

Note 1: “scanme.nmap.org” website is used to practice nmap commands.

- **nmap --help**: command for the information related to the NMAP. **nmap scanme.nmap.org >> test.txt**: It will scan for 1000
- starting open ports that are available on the website not all 65536 ports and save to test.txt file. **nmap -oG - 192.168.1.0-255 -p 22 -vv > /home/seize/Desktop/harsh**: It is used to save the data neatly or in graphable output in already saved file at some
- place. Here, -vv used for double Verbose scan, -p for specifying some port otherwise leave it. **nmap -A scanme.nmap.org**: It is used for aggressive scanning where, -A enable OS detection, version detection, script scanning and traceroute. **nmap -sV**
- **scanme.nmap.org**: This command is used for detecting the services version like which OS used and much more. **nmap -F scanme.nmap.org**: Here, -F is used for fast scan which include common port scanning (ssh, http, and much more). **nmap -F**
- **scanme.nmap.org www.google.com 192.168.0.1**: It is used for Multiple scan. **nmap --open www.google.com**: It is used for
- checking only Open ports. **nmap -sT IP_ADDRESS**: It is used for Capturing TCP packets and for that please run wireshark tool
- simultaneously. **nmap -sU IP_ADDRESS**: It is used for Capturing TCP packets and for that please run wireshark tool
- simultaneously.
-
-

Note 2: We can also use nslookup commands for scanning informations like name, IP address, and much crucial information. Command: nslookup WEBSITE_NAME_OR_IP_ADDRESS **Note 3:** There are 3 main types of states which include: Open (open port and ready to build connection), Close (close port and can’t build up connection), Filtered (Port is undetectable by nmap and it can be open or close.)

PRACTICAL EXERCISE 2

Nmap Tool: Identifying Open Ports and Services

Purpose and Activity

01 Here we are using nmap tool and checking for open ports and services via different Commands of Nmap Tool.

02 Also we will be looking for Nmap Scripting Engine and it’s use



PRACTICAL EXERCISE 2.1

Host Discovery

- **nmap -sn 192.168.1.1**: -sn is a ping sweep. **nmap -sn**
- **192.168.1.1/24**: scanning whole network with /24. **man nmap |**
- **grep sn**: man is used for displaying options. **nmap -Pn**
- **192.168.1.1/24**: It will show those ports which are up.

OS and Service Version scanning

- **nmap -O 192.168.1.1 nmap -O -sV 192.168.1.1 nmap -A 192.168.1.1 -p-**
- **Stealth scanning**
- **nmap -sS 192.168.1.1 nmap -sS -sV 192.168.1.1 nmap -sS -sV 192.168.1.1 -p 21-8000**

Output and Verbosity

- **nmap -sS 192.168.1.1 -oA/-oN/-oX/-oG FILE_NAME**: -oA (for saving output in all file mode which include: .gnmap, .nmap, .xml), -oN (for saving output in human readable format), -oX (in .xml format), -oG (for grapable format) **nmap -sS -v**
- **192.168.1.38 -oN FILE_NAME**: -v for single verbosity, -vv for double verbosity, and -vvv for triple verbosity and for Decrease
- the length of output and wanted point to point answer we can use -d and it's 3 levels (like -d, -dd, -ddd).

PRACTICAL EXERCISE 2.2

Inverse TCP flag scanning (FIN,XMASandNULL)

- **nmap -sX 192.168.1.22 --reason**: xmas = fin, urgent and push flags are going in xmas scan.
- **nmap -sF/-sN 192.168.1.22 --reason**: -sF for finish flag, -sN for null.

Firewall detection (ACK probing)

Note 1: In firewall detection we are taking help of ACK prob that means sending ack flag so if we get a response and get the flags like rst then firewall is not there and if we don't get a response then the firewall is there.

- **nmap -sA 192.168.1.38 --reason nmap -sA 192.168.1.1 -p 22 --reason**
- **firewall evasion (decoys, MTU and fragmentation)**
  nmap -sS -sV -F -D RND:3 nmap.scanme.org: -sS (syn packet), -F (fast scan only 100 ports), -D (for decoy that i have to hide my IP address and change it to any other IP address), and RND:3 is for randomly IP generation by the nmap but we can
- mention also by writing IP address at the place of RND:3. **nmap -sS -sV -F -f --send-eth -D 171.124.180.173 nmap.scanme.org**: -f --send-eth is used for fragmenting the data into 8 bytes small packets (otherwise 4 bytes by default).
  nmap -sS -sV -F --mtu 16 --send-eth -D 171.124.180.173 nmap.scanme.org: --mtu is used for mentioning the size of the
- data units to be send and it can be like 8,16,24,32 bytes.

PRACTICAL EXERCISE 2.3

Nmap Scripting Engine

- **NSE** is used for Automating the manual Nmap scans and testing. (https://nmap.org/book/nse.html#nse-intro)
- There are a lot of scripts available in the NSE with extension **.nse** which is written in **LUA programming** or scripting language and to access them we can go for following commands:
  - **ls -al /usr/share/nmap/scripts/**: For all scripts. **ls -al /usr/share/nmap/scripts/ | grep -e "http"**: For specific
  - script. **ls -al /usr/share/nmap/scripts/ | grep -e "http-enum"**: For specific script. **vim**
  - **/usr/share/nmap/scripts/http-enum.nse**: From this command we can create our own scripts. Here, we are
  - making changes in the existing one but we can create it by giving “**nano**” command.

NSE Syntax

- Before running the scripts, please make sure to update the scripts and **check** for **Up Hosts** and **Open Ports**:
  - **sudo nmap --script-updatedb**: Updating the NSE scripts **nmap -sn/-sV 192.168.1.149**: Checking for Up hosts and Open
  - ports. **nmap -p 21 --script ftp-anon 192.168.1.149**: Here, we are applying ftp-anon script which checks for **anonymous**
  - **login** into system. We can also apply multiple scripts in one command by separating the scripts with **comma** and most important if you wanted to apply all scripts related to any particular service then go for **“ftp-*”** all sign. **ftp IP_ADDRESS**: for logging into the system with credentials - name=**anonymous**, password=**ENTER**.
  -

PRACTICAL EXERCISE 3

BannerGrabbingandNetworkEnumeration

In this practical, we will be looking for Banner grabbing and Network enumeration techniques which include Introduction and use of Multiple tools for them.



PRACTICAL EXERCISE 3.1

Banner Grabbing

It is a technique used in cybersecurity to collect information about a computer system or a service running on a network. The "banner" is the initial message or information sent by a service when a connection is made, which can provide details like the software name, version, operating system, or other metadata.

Types of Banner Grabbing

- **Active Banner Grabbing**: Directly interacts with the service or server to solicit a response in which tools like Telnet, Netcat, or Nmap are used to manually or automatically send requests and collect banners. **Passive Banner Grabbing**: Observes
- traffic without directly interacting with the system in which tools like Wireshark are used to analyze network packets and extract banners.

Network Enumeration

It is the process of gathering information about a network to identify its structure, hosts, devices, and available services. It involves probing the network to collect detailed data that can be used for network analysis, security assessments, or even potential attacks.

Types of Banner Grabbing

- **Active Enumeration**: Actively interacts with the network to probe and collect data (e.g., using tools like Nmap or Nessus) and which is often generates detectable network traffic. **Passive Enumeration**: Observes and analyzes existing network
- traffic without directly interacting with the network in which tools like Wireshark are used for this method.

PRACTICAL EXERCISE 3.2

Banner Grabbing

Nmap Scripting Engine

- nmap -sV IP_ADDRESS sudo nmap -p22,80 --script
- banner 192.168.1.217 sudo nmap -F -T4 --script
- banner 192.168.1.217

Netcat (nc) Method

- nc IP_ADDRESS PORT

Telnet Method

- telnet IP_ADDRESS PORT

Whatweb Method

sudo apt install whatweb
whatweb IP_ADDRESS_OR_URL

Wireshark Method (Passive)

- Capture the Network traffic and apply filter so that you will see specific traffic: **http || ftp** Inspect captured
- packets and look for **banners** in the **Server** or **User-Agent fields of HTTP headers** and we can also check the first response packet from the server for metadata.

PRACTICAL EXERCISE 3.3

Network Enumeration

Nmap

- **nmap -sn 192.168.1.0/24**: For ping sweep **nmap -p 1-65535 IP_Address**:
- Scans for Open Ports and running services **nmap -O IP_Address**: OS
- Fingerprinting **nmap -sV IP_Address**: Service Enumeration
-

SNMP, DNS, SMB, LDAP and FTP enumeration

- **snmpwalk -v 2c -c public IP_ADDRESS**: Gathers information using the Simple Network Management Protocol (SNMP).
- **dnsenum example.com**: Enumerates DNS records to find subdomains, MX records, etc. **dig example.com ANY**:
- Enumerates DNS records to find subdomains, MX records, etc. **enum4linux -a IP_ADDRESS**: Targets Windows shares and
- resources over the Server Message Block (SMB) protocol. **ldapsearch -x -h IP_ADDRESS -b "dc=example,dc=com"**:
- Retrieves directory information using Lightweight Directory Access Protocol (LDAP). **nmap -p 21 -sS -script ftp-anon,ftp-syst,ftpp-enum,ftp-vsftpd-backdoor 102.168.1.149 192.168.1.38**: FTP enumeration
-

Wireshark Method (Passive)

- Capture the Network traffic and apply filter so that you will see specific traffic: **arp || tcp**
- Inspect captured packets and look for the **arp and tcp requests and response** .

PRACTICAL EXERCISE 4

Steganography

01 Here, For understanding the steganography process in practical terms we will be using a tool named as: Steghide. It is a steganography tool that lets you hide and extract data within image (JPEG, BMP) or audio files (WAV, AU).

02 **Exercise:** Install steghide tool on your linux system. Practice steghide commands and use in basic terms as well as advanced terms. Also hide stegfile in some other file so that it can be sended through over the internet and if captured then attacker can't take the advantage of it.



PRACTICAL EXERCISE 4.1

Steghide Commands

Embedding Data in a file

- **steghide embed -cf COVER_FILE -ef EMBED_FILE -p PASSWORD**: -cf (Image/audio file), -ef (text file), -p (Optional password), -q (no output unless error occur), -v (Verbose mode).

Extracting Data from a file

- **steghide extract -sf STEGO_FILE -p PASSWORD**: -sf is Stego file (File containing the hidden data), and if no password then leave -p, -xf (For specifying path of stego file).

Checking File Information

- **steghide info FILE**

Specifying Compression and Encryption Options

- **steghide embed -cf image.jpg -ef secret.txt -z 9 -e aes-256 -p mypassword**

-z = Compression level (0-9; 0 disables compression).
-e = Encryption algorithm (e.g., aes-128, rc4, etc.).

Changing File Names or Data

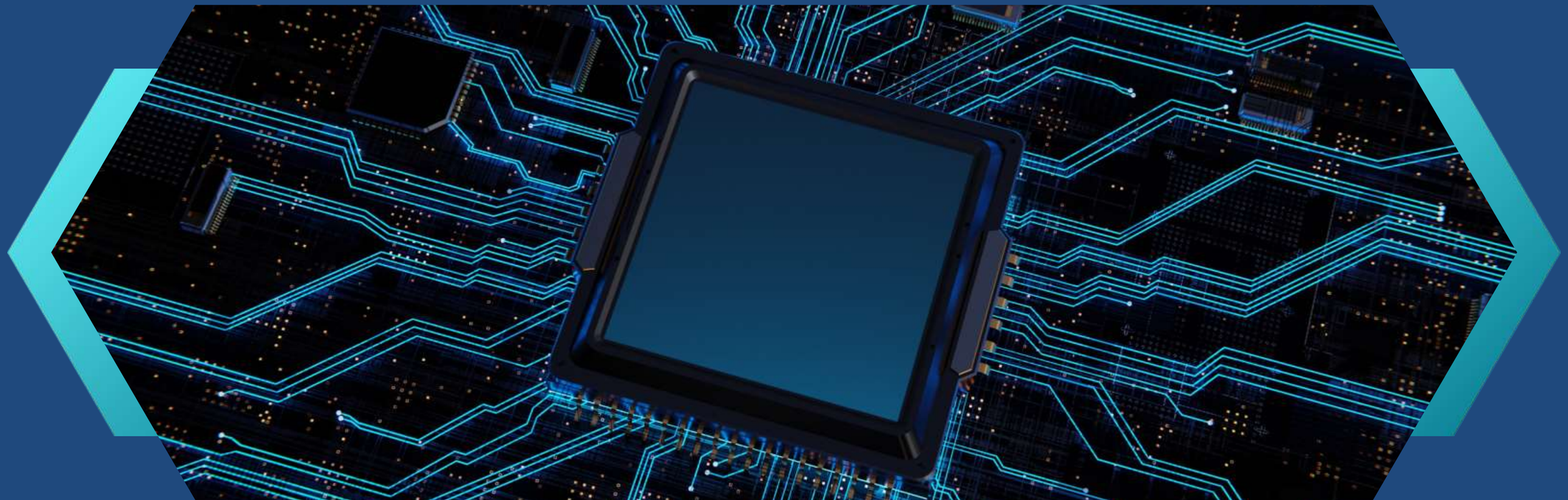
steghide embed -cf image.jpg -ef secret.txt -p mypassword -sf new_image.jpg: -sf (name of the new stego file).

Note 1: For advance steganography tools we can go for: OpenStego (GUI), Stegano (Python Library), Outguess (Advance tool), SilentEye (For Large data).

PRACTICAL EXERCISE 5

Hping
(Optional)

Hping is a powerful network tool often used for TCP/IP packet crafting, network scanning, and security testing.



PRACTICAL EXERCISE 5.1

Hping3 Commands

ICMP Ping

- **hping3 -1 IP_ADDRESS**: Sends ICMP Echo Request packets to the target to check if the host is alive and reachable.

ACK Scan on Port 80

hping3 -A IP_ADDRESS -p 80: Sends TCP ACK packets to target's port to detect open ports and firewall. If no response, the port may be filtered.

UDP Scan on Port 80

- **hping3 -2 IP_ADDRESS -p PORT**: Sends UDP packets to check for open UDP ports (no response = Open Port or filtered if using a firewall).

Collecting Initial Sequence Numbers

- **hping3 IP_ADDRESS -Q -p 139 -s**: Captures TCP sequence numbers on port 139 of Target's IP for analyzing TCP sequence predictability (helpful in TCP-based attacks like session hijacking).

Firewalls and Timestamps

- **hping3 -S IP_ADDRESS -p 80 --tcp-timestamp**: Sends SYN packets to target's port with TCP timestamps for detecting firewall rules and analyzing packet timing.

PRACTICAL EXERCISE 5.2

Hping3 Commands

SYN Scan on Ports 50-60

- **hping3 -8 50-60 -S IP_ADDRESS -V**: Scans ports 50-60 on the target's IP using SYN packets. -V (verbose output).

FIN, PUSH, and URG Scan on Port 80

- **hping3 -F -P -U IP_ADDRESS -p 80**: Sends TCP packets with FIN, PUSH, and URG flags set to port 80 for detecting unusual responses from firewalls or hosts.

Scanning an Entire Subnet for Live Hosts

- **hping3 -1 10.0.1.x --rand-dest -I eth0**: Sends ICMP packets to random IP addresses in the 10.0.1.x subnet through interface eth0 which identifies live hosts in the subnet.

Intercept Traffic Containing an HTTP Signature

- **hping3 -9 HTTP -I eth0**: Monitors traffic on interface eth0 and filters packets containing "HTTP" in the payload.

SYN, UDP, ICMP, HTTP-Focused Flooding a Victim (DOS attack)

- **hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood**: Launches a SYN flood attack/DOS attack against 192.168.1.1 on port 22, spoofing the source IP as 192.168.1.254. The --flood flag sends packets as fast as possible.
- **hping3 -2 IP_ADDRESS --flood**: Floods the target with UDP packets, for overwhelming the target's ability to handle them.
- **hping3 -1 IP_ADDRESS --flood**: Overloads the target with ICMP Echo Request packets (ping flood).
- **hping3 -9 HTTP -I eth0 --flood**: Targets HTTP traffic by flooding packets with an HTTP signature in the payload.

THANK YOU